Ciberseguridad Aplicada

Clase 7 Unidad VIII y Unidad IX

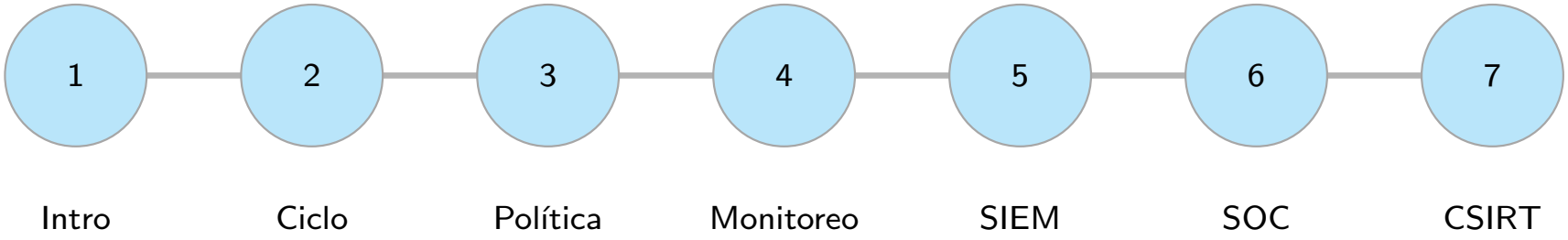
Gestión de Incidentes y Herramientas de Open Source

5 de octubre de 2026

Ruta de la Clase 7 : Unidad VIII y Unidad IX

UNIDAD VIII	**UNIDAD IX**
Gestión de incidentes  Estamos aquí	Herramientas open source

Recorrido de la Clase: Gestión de Incidentes



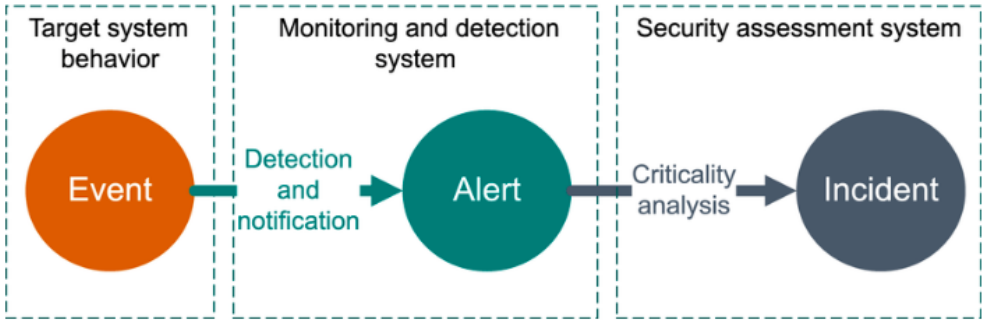
T1 Introducción: Conceptos de incidente
T2 Ciclo de gestión de incidentes
T3 Roles y gobernanza
T4 Monitoreo y detección
T5 SIEM y correlación
T6 SOC (análisis)
T7 CSIRT (respuesta)

¿Qué es un Evento?

Definición

Es cualquier ocurrencia observable en un sistema, servicio, red o infraestructura tecnológica que puede ser registrada y analizada. Los eventos pueden corresponder a actividades normales o anómalas y constituyen la materia prima para la detección de incidentes de seguridad [1, 2].

- Inicio de sesión de un usuario.
- Acceso a un archivo o recurso.
- Cambio de configuración.
- Conexión de red.
- Instalación o ejecución de software.
- Reinicio de un sistema.



Importante: un evento no implica necesariamente un incidente de seguridad.

Evento, Alerta e Incidente

$$\text{Evento} \rightarrow \text{Alerta} \rightarrow \text{Incidente}$$

- **Evento:** cualquier actividad observable registrada por un sistema, aplicación o dispositivo.
- **Alerta:** notificación generada cuando uno o más eventos presentan características que podrían indicar una amenaza o comportamiento anómalo y requieren análisis.
- **Incidente:** evento o conjunto de eventos que comprometen la confidencialidad, integridad o disponibilidad de la información y requieren respuesta.

Ejemplo

- Evento: múltiples intentos de inicio de sesión.
- Alerta: el sistema detecta 50 intentos fallidos en 5 minutos.
- Incidente: se confirma un ataque de fuerza bruta contra una cuenta.

¿Qué es un Incidente de Seguridad?

Definición

Un incidente de seguridad es un evento o conjunto de eventos que comprometen, o tienen una probabilidad significativa de comprometer, la confidencialidad, integridad o disponibilidad de la información, los sistemas o los servicios de una organización [1, 2].

Ejemplos de incidentes de seguridad:

- Infección por malware o ransomware.
- Acceso no autorizado a sistemas o cuentas.
- Fuga o exposición de información sensible.
- Ataques de denegación de servicio (DoS/DDoS).
- Modificación no autorizada de datos.
- Compromiso de credenciales.

Importante

No todo evento constituye un incidente. Un incidente requiere la confirmación de un impacto real o potencial sobre la seguridad de la información y demanda acciones de respuesta y mitigación.

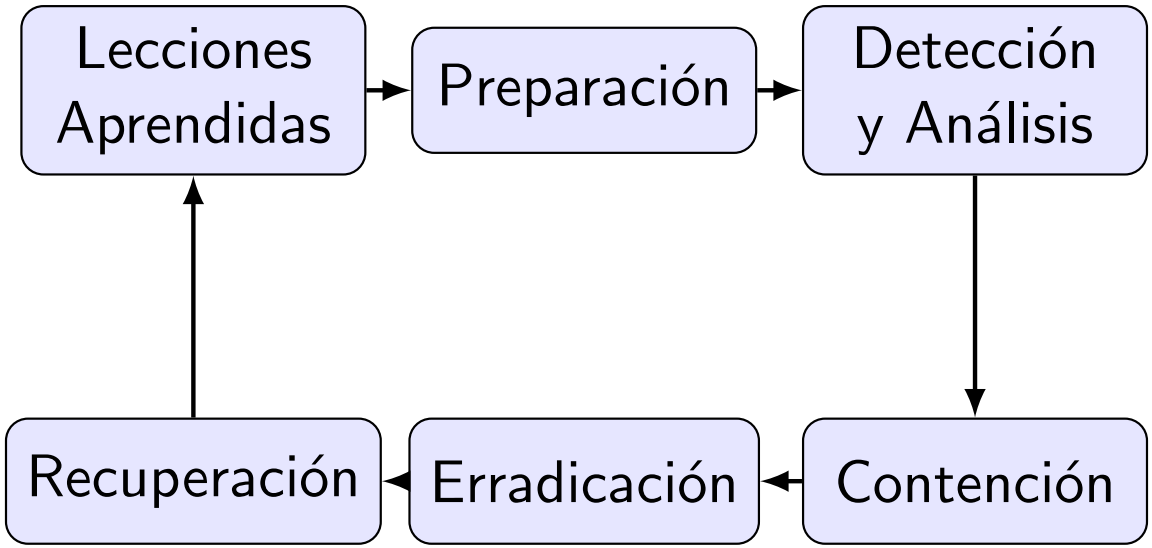
¿Por qué gestionar incidentes?

Objetivo

La gestión de incidentes tiene como finalidad minimizar el impacto de los incidentes de seguridad sobre los activos de información y las operaciones de una organización, garantizando una respuesta eficaz y una recuperación oportuna [1, 2, 3].

- Reducir el impacto operacional, económico y reputacional.
- Detectar y contener amenazas de manera temprana.
- Preservar evidencias para investigaciones y análisis forense.
- Recuperar servicios y restablecer la operación normal.
- Identificar vulnerabilidades y oportunidades de mejora.
- Cumplir requisitos normativos y regulatorios.
- Fortalecer la resiliencia y la continuidad operativa.

Ciclo de Gestión de Incidentes



El ciclo presentado constituye uno de los modelos de referencia más difundidos para la gestión de incidentes de seguridad y se encuentra alineado con las prácticas recomendadas por NIST y los lineamientos establecidos por la norma ISO/IEC 27035 para equipos de respuesta a incidentes (CSIRT) [4] y centros de operaciones de seguridad (SOC)[1, 2].

Etapas del Ciclo

Preparación	Políticas, capacitación, herramientas y procedimientos.
Detección y análisis	Identificación y clasificación del incidente.
Contención	Limitar el alcance y propagación.
Erradicación	Eliminar la causa raíz.
Recuperación	Restablecer servicios afectados.
Lecciones aprendidas	Mejorar controles y procesos.

Fuente: Adaptado de NIST SP 800-61 Rev.3 e ISO/IEC 27035.

Preparación: Capacidades Previas

Idea Central

La gestión de incidentes depende de capacidades de seguridad previamente implementadas en la organización.

- Gestión de activos → Unidad IV
- Gestión de riesgos → Unidad V
- Gestión de identidades y accesos (IAM) → Unidad VI
- Gestión de vulnerabilidades → Unidad VII
- Segmentación de redes → Unidad VII
- Monitoreo y registro de eventos → Unidad VIII
- Políticas, procedimientos y capacitación

La gestión de incidentes integra conocimientos desarrollados a lo largo de la primera parte de la materia.

Preparación

Principio Fundamental

No se puede proteger lo que no se conoce. La gestión de activos permite saber qué proteger; la gestión de riesgos ayuda a decidir qué es prioritario; la gestión de identidades y accesos determina quién puede acceder a cada recurso; y la gestión de vulnerabilidades permite identificar y corregir debilidades que podrían ser explotadas por una amenaza.

Preparación: Relación entre las Capacidades

Gestión de Activos → Saber qué proteger

↓

Gestión de Riesgos → Saber qué priorizar

↓

IAM → Controlar quién accede

↓

Gestión de Vulnerabilidades → Identificar y corregir debilidades

↓

Segmentación de Redes → Limitar la propagación

↓

Monitoreo → Detectar incidentes

Conclusión

La gestión de incidentes no funciona de manera aislada; depende de capacidades de seguridad previamente implementadas.

Preparación: Capacidades Requeridas

Capacidad	**Ejemplos**
Organizacional	Política de gestión de incidentes, CSIRT (*Computer Security Incident Response Team*) y definición de roles y responsabilidades.
Humana	Capacitación, concientización y simulacros para mejorar la capacidad de respuesta.
Tecnológica	SIEM (*Security Information and Event Management*), EDR (*Endpoint Detection and Response*), IDS (*Intrusion Detection System*), IPS (*Intrusion Prevention System*) y monitoreo de eventos.
Operativa	Procedimientos de detección, respuesta, recuperación, comunicación y escalamiento de incidentes.

La preparación combina capacidades organizacionales, humanas, tecnológicas y operativas que permiten detectar, contener y recuperarse de incidentes de seguridad.

Detección y Análisis

Concepto Clave

La detección requiere comprender el comportamiento esperado de usuarios, sistemas y redes para identificar desviaciones, tendencias inusuales o patrones compatibles con actividades maliciosas.

- Líneas base de comportamiento.
- Umbrales y reglas de alerta.
- Correlación de eventos.
- Análisis de tendencias y evolución temporal.
- Detección basada en comportamiento.

Detección y Análisis

Objetivo

Identificar actividades anómalas, determinar si constituyen incidentes de seguridad y evaluar su alcance e impacto.

- Recolección y centralización de eventos y logs.
- Establecimiento de líneas base de comportamiento normal.
- Definición de umbrales para la generación de alertas.
- Correlación de eventos provenientes de múltiples fuentes.
- Detección de comportamientos anómalos o indicadores de compromiso (IoC por sus siglas en inglés *Indicator of Compromise*).
- Análisis de evidencias y validación del incidente.
- Clasificación según criticidad, impacto y urgencia.
- Determinación del alcance y activos afectados.

Fuentes de Información para la Detección

Fuente	**Ejemplos**
Sistemas operativos	Eventos de autenticación, auditoría y cambios de configuración.
Redes	Firewalls, IDS (*Intrusion Detection System*), IPS (*Intrusion Prevention System*), routers y switches.
Aplicaciones	Errores, accesos y actividad de usuarios.
Seguridad	EDR (*Endpoint Detection and Response*), antivirus, SIEM (*Security Information and Event Management*) y *honeypots* (sistemas señuelo).
Inteligencia	IoC (*Indicator of Compromise*) y CTI (*Cyber Threat Intelligence*).

Contención

Objetivo

Limitar el alcance y reducir el impacto del incidente, evitando su propagación hacia otros sistemas o servicios.

- Aislamiento de sistemas comprometidos.
- Segmentación o restricción de comunicaciones de red.
- Bloqueo temporal de cuentas, direcciones IP o servicios.
- Aplicación de reglas de contención en firewalls y sistemas de seguridad.
- Preservación de evidencias para el análisis forense.
- Implementación de medidas temporales mientras se determina la causa raíz.

Estrategias de Contención

- **Contención a corto plazo:** Aislar rápidamente el sistema afectado para detener el daño inmediato.
- **Contención a largo plazo:** Implementar controles temporales que permitan mantener la operación mientras se corrige la causa raíz.
- **Contención segmentada:** Restringir únicamente los sistemas afectados para minimizar el impacto sobre el resto de la organización.

Principio

La contención debe equilibrar la reducción del impacto del incidente con la continuidad de las operaciones.

Erradicación

Objetivo

Eliminar la causa raíz del incidente y los elementos que permitieron el compromiso del sistema.

- Eliminación de malware, herramientas maliciosas o archivos comprometidos.
- Corrección de vulnerabilidades mediante parches o cambios de configuración.
- Eliminación de mecanismos de persistencia utilizados por el atacante.
- Revocación o restablecimiento de credenciales comprometidas.
- Verificación de que no permanezcan indicadores de compromiso (IoC).

Recuperación

Objetivo

Restablecer los sistemas y servicios afectados, verificando que operen de manera segura y normal.

- Restauración de sistemas, servicios y datos afectados.
- Validación del correcto funcionamiento de los activos recuperados.
- Monitoreo reforzado para detectar posibles recaídas o actividades residuales.
- Verificación de la efectividad de las medidas implementadas.
- Retorno gradual a la operación normal.

Lecciones Aprendidas

Objetivo

Analizar el incidente para identificar oportunidades de mejora y fortalecer las capacidades de seguridad de la organización.

- Identificación de la causa raíz y factores contribuyentes.
- Documentación del incidente y de las acciones realizadas.
- Evaluación de la efectividad de la respuesta.
- Actualización de procedimientos, políticas y planes de respuesta.
- Implementación de mejoras en controles técnicos y organizacionales.
- Capacitación y transferencia de conocimientos al personal.

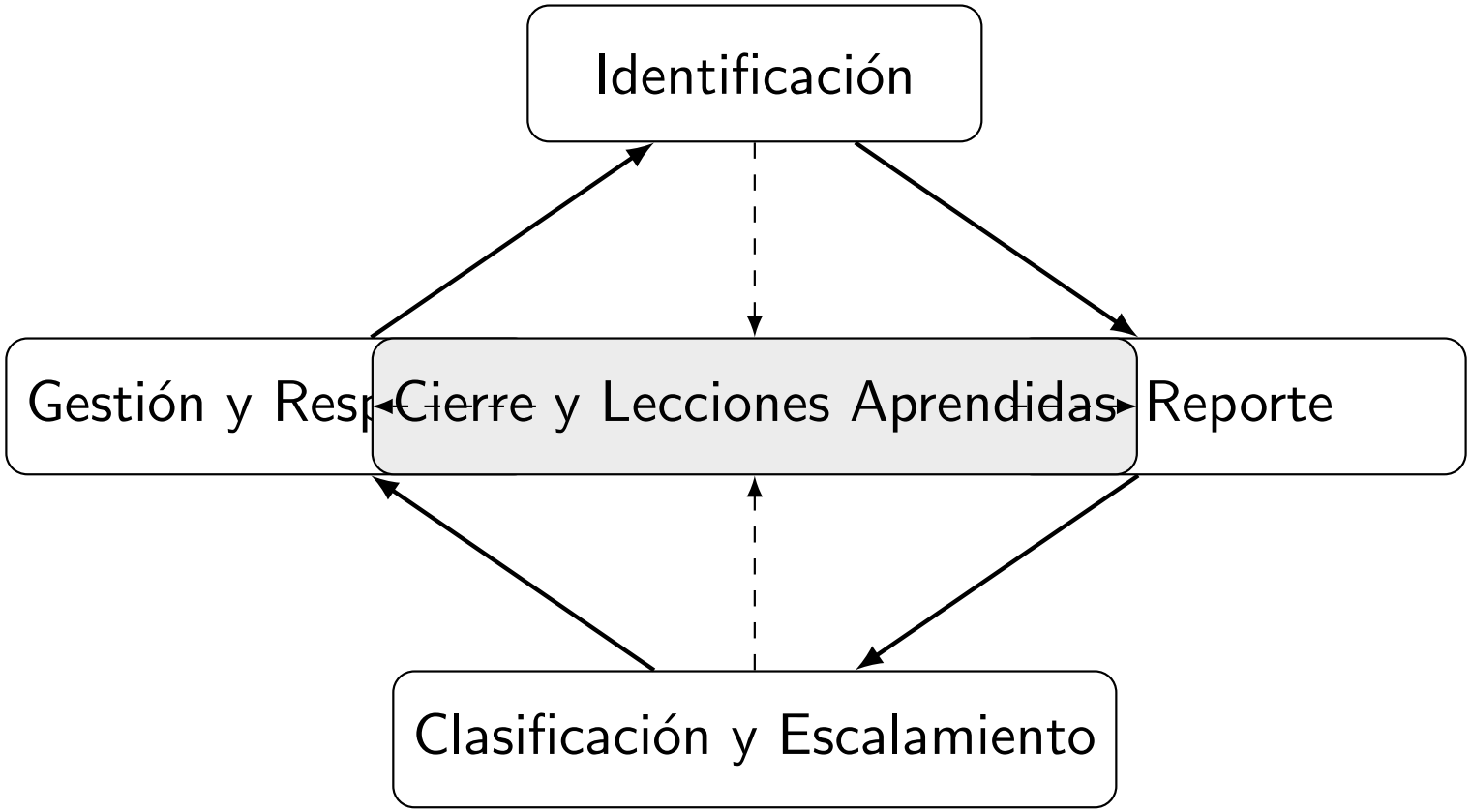
Gobernanza

Objetivo

Establecer la dirección, supervisión y coordinación necesarias para gestionar los incidentes de seguridad de manera consistente y alineada con los objetivos de la organización.

- Definir roles, responsabilidades y autoridades.
- Asignar recursos humanos, tecnológicos y financieros.
- Aprobar políticas, procedimientos y planes de respuesta.
- Supervisar el cumplimiento de los procesos establecidos.
- Establecer requisitos de confidencialidad y protección de la información.
- Garantizar la trazabilidad y rendición de cuentas de las acciones realizadas.

Política de Gestión de Incidentes



Fuente: Adaptado de NIST SP 800-61 Rev.2 e ISO/IEC 27035.

Política de Gestión de Incidentes

Principio

La política establece criterios comunes para identificar, reportar, clasificar, gestionar y cerrar incidentes de seguridad de manera consistente.

- Definición de incidente de seguridad.
- Roles y responsabilidades de los participantes.
- Mecanismos de reporte y notificación.
- Criterios de clasificación y priorización.
- Escalamiento y comunicación.
- Requisitos de confidencialidad y manejo de la información.
- Registro, documentación y cierre del incidente.

Adaptado de NIST SP 800-61 Rev.2 (Computer Security Incident Handling Guide)[1] ISO/IEC 27035 (Information Security Incident Management) [2], ISO/IEC 27002 (Controles de Seguridad de la Información) [5] y FIRST CSIRT Services Framework [4].

Reflexión

Un incidente de seguridad no se gestiona únicamente con tecnología.

Requiere personas, procesos, procedimientos, coordinación y toma de decisiones.

Usuarios $\rightarrow$ Administradores $\rightarrow$ SOC/CSIRT $\rightarrow$ Dirección

Conclusión

La eficacia de la respuesta depende tanto de las capacidades técnicas como de la coordinación entre los distintos actores de la organización.

Para Recordar

Un incidente puede ser detectado por cualquier persona dentro de la organización. La diferencia entre un problema menor y una crisis suele depender de que cada actor conozca cuándo reportar, a quién informar y qué acciones realizar.

Roles y Responsabilidades

Principio

La definición clara de roles y responsabilidades favorece la coordinación, la trazabilidad y la rendición de cuentas durante la gestión de incidentes.

Las responsabilidades deben asignarse siguiendo principios como mínimo privilegio, segregación de funciones y necesidad de conocer (*need to know*).

Roles y Responsabilidades

Rol	**Responsabilidades**
Usuario	Detectar actividades sospechosas y reportar incidentes según los procedimientos establecidos.
Propietario del Activo	Determinar la criticidad del activo, validar impactos y participar en la toma de decisiones relacionadas con el incidente.
Administrador / Custodio	Implementar controles técnicos, aplicar medidas de contención, recuperación y corrección sobre los sistemas afectados.
SOC	Monitorear eventos de seguridad, analizar alertas e identificar incidentes para su escalamiento.
CSIRT	Coordinar la respuesta, investigar el incidente, gestionar la contención, erradicación y recuperación, y documentar las acciones realizadas.
Dirección	Tomar decisiones estratégicas, asignar recursos y aprobar acciones que puedan afectar la operación de la organización.

Adaptado de NIST SP 800-61 Rev.2, ISO/IEC 27035 y FIRST CSIRT Services Framework.

¿Qué es el Monitoreo de Seguridad?

Definición

Proceso continuo de observación, recolección y análisis de eventos generados por sistemas, redes, aplicaciones y usuarios con el objetivo de detectar actividades anómalas o incidentes de seguridad.

- Permite identificar comportamientos inusuales.
- Facilita la detección temprana de incidentes.
- Proporciona evidencias para el análisis e investigación.
- Contribuye a la respuesta y recuperación ante incidentes.

¿Qué es un Log?

Definición

Un log es un registro cronológico de eventos generados por sistemas, dispositivos, aplicaciones o usuarios durante su funcionamiento.

- Accesos exitosos y fallidos.
- Cambios de configuración.
- Ejecución de aplicaciones.
- Eventos de red.
- Actividades administrativas.

Fuentes de Información

- Sistemas Operativos.
- Dispositivos de red (routers y switches).
- Firewalls.
- IDS (*Intrusion Detection System*).
- IPS (*Intrusion Prevention System*).
- EDR (*Endpoint Detection and Response*).
- Aplicaciones y bases de datos.
- Servicios de autenticación e IAM.

¿Qué Buscamos Durante el Monitoreo?

- Actividades anómalas.
- Violaciones de políticas de seguridad.
- Intentos de acceso no autorizado.
- Comportamientos compatibles con amenazas conocidas.
- Indicadores de Compromiso (IoC).

Indicadores de Compromiso (IoC)

Definición

Los Indicadores de Compromiso (IoC) son evidencias observables que sugieren que un sistema, usuario o red podría haber sido comprometido por una actividad maliciosa.

- Direcciones IP asociadas a actividades maliciosas.
- Dominios o URL utilizados por atacantes.
- Hashes de archivos maliciosos.
- Procesos o servicios inusuales.
- Creación de cuentas no autorizadas.
- Intentos reiterados de autenticación fallidos.
- Conexiones de red anómalas.
- Modificaciones inesperadas de archivos o configuraciones.

¿Por Qué Surge un SIEM?

Problema

Las organizaciones generan miles o millones de eventos diarios provenientes de múltiples sistemas y dispositivos.

- Sistemas operativos.
- Firewalls.
- IDS/IPS.
- EDR.
- Aplicaciones.
- Servicios de autenticación.

Necesidad

Centralizar, correlacionar y analizar eventos para detectar incidentes de seguridad de manera eficiente.

¿Qué es un SIEM?

SIEM

SIEM: **Security Information and Event Management** (Gestión de Información y Eventos de Seguridad)

Definición

Plataforma que recopila, centraliza, normaliza y correlaciona eventos de seguridad provenientes de múltiples fuentes para su análisis y detección de incidentes.

Logs + Eventos + Contexto = Detección de incidentes

Funciones de un SIEM

- Centralización de logs y eventos.
- Normalización de información proveniente de múltiples fuentes.
- Correlación de eventos relacionados.
- Generación de alertas.
- Búsqueda e investigación de incidentes.
- Auditoría y trazabilidad.
- Generación de reportes y métricas.
- Apoyo a actividades de cumplimiento normativo.

Reglas de detección en un SIEM

¿Qué son las reglas?

Son condiciones definidas para identificar comportamientos sospechosos a partir de eventos y logs.

Tipos principales de reglas:

- **Reglas de correlación:** relacionan múltiples eventos en el tiempo o entre fuentes distintas.
- **Reglas basadas en umbrales:** se activan cuando un valor supera un límite definido.
- **Reglas de coincidencia directa:** detectan eventos específicos (ej. IP en blacklist).
- **Reglas basadas en comportamiento:** detectan desviaciones respecto a lo "normal".

Idea clave

Las reglas transforman eventos aislados en alertas con contexto.

¿Qué es la Correlación de Eventos?

Concepto

Consiste en relacionar eventos provenientes de distintas fuentes para identificar patrones que, de manera aislada, podrían pasar desapercibidos.

Ejemplo

1. Múltiples intentos fallidos de autenticación.
2. Inicio de sesión exitoso.
3. Creación de una nueva cuenta administrativa.
4. Conexión hacia una IP externa desconocida.

Cada evento por separado puede parecer normal; juntos pueden indicar un compromiso.

¿Qué es un SOC?

Definición

Un SOC (Security Operations Center) es un centro de operaciones de seguridad encargado de monitorear, detectar, analizar y responder a incidentes de ciberseguridad en una organización.

Funciones principales:

- Monitoreo continuo de eventos de seguridad.
- Detección de comportamientos anómalos.
- Análisis y clasificación de incidentes.
- Coordinación de la respuesta y mitigación.

Objetivo: Reducir el impacto de incidentes mediante detección temprana y respuesta coordinada.

Relación entre SIEM y SOC

Idea clave

El SIEM no es el centro de la operación de seguridad: es una plataforma que automatiza la detección a partir de reglas definidas por el equipo de seguridad.

Diferencia conceptual:

- **SIEM:** recopila, normaliza y ejecuta reglas de detección sobre eventos.
- **SOC:** diseña reglas, analiza alertas, investiga y coordina la respuesta.

Relación práctica:

$$\text{Logs y eventos} \rightarrow \text{SIEM (aplica reglas)} \rightarrow \text{alertas} \rightarrow \text{SOC}$$

La utilidad del SIEM no radica en la tecnología por sí sola, sino en la calidad de las reglas implementadas y en la capacidad analítica del SOC para interpretar los eventos.

¿Qué es un CSIRT?

Definición

Un CSIRT (Computer Security Incident Response Team) es el equipo responsable de coordinar la contención, erradicación y recuperación ante incidentes de seguridad.

Funciones principales:

- Contener el impacto del incidente.
- Coordinar acciones técnicas y organizacionales.
- Erradicar la causa raíz.
- Recuperar la operación normal.

Relación con el SOC

El CSIRT actúa cuando el SOC ya identificó y validó el incidente.

CERT vs CSIRT

CERT (histórico):

- Primer modelo creado en Carnegie Mellon (1988).
- Surge tras incidentes tempranos de malware (Morris Worm).
- Término original del concepto de respuesta a incidentes.

CSIRT (actual):

- Término más general y moderno.
- Usado internacionalmente por gobiernos y organizaciones.
- No depende de una marca específica.

Conclusión

CERT es el origen histórico, CSIRT es la evolución operativa moderna.

Funciones operativas del CSIRT

Durante un incidente:

- Aislamiento de equipos comprometidos
- Bloqueo de IPs, dominios o hashes maliciosos
- Eliminación de malware o accesos no autorizados

Después del incidente:

- Análisis forense básico
- Recolección de evidencias
- Reporte final del incidente
- Recomendaciones de mejora

Relación entre SOC y CSIRT

Diferencia clave

El SOC detecta y analiza, el CSIRT ejecuta la respuesta.

Flujo operativo:

$$\text{Alertas (SIEM)} \rightarrow \text{SOC} \rightarrow \text{CSIRT} \rightarrow \text{Contención}$$

Interpretación:

- SOC = decisión
- CSIRT = acción

Bibliografía I


National Institute of Standards and Technology, "Computer security incident handling guide," Tech. Rep. SP 800-61 Revision 2, National Institute of Standards and Technology, Gaithersburg, MD, USA, 2012.


"Iso/iec 27035-1: Information security incident management," 2023.


European Union Agency for Cybersecurity, "Good practice guide for incident management," 2010.


FIRST, *CSIRT Services Framework*.
Forum of Incident Response and Security Teams, version 2.1 ed., 2024.

Bibliografía II

 International Organization for Standardization, *ISO/IEC 27002:2022 Information Security, Cybersecurity and Privacy Protection — Information Security Controls*, 2022.